

Windows Security & Active Directory

Windows Gives Attackers the Kingdom

Most enterprises run Windows clients + Active Directory. AD holds the crown jewels: user accounts, groups, GPOs, domain trusts. Attackers target it relentlessly – that's why AD attacks (Kerberoasting, Pass-the-Hash, Golden Ticket) dominate red team playbooks.

Windows Authentication Basics

Windows authenticate several ways:

Kerberos – default for domain: AS-REQ/AS-REP (ticket granting), TGS

NTLM – legacy challenge/response

Kerberos AD components: Domain Controller (DC) runs KDC

Event IDs You MUST Know (SOC-Speak)

Event ID	Meaning
4624	Successful logon
4625	Failed logon
4648	Logon with explicit credentials (runas)
4688	New process created (with CommandLine if enabled)
4720	New user created
4728/4732/4756	User added to privileged groups
7045	New service installed (WITHOUT MSI) – persistence!
1102	Security log cleared (eradication!)

Registry

Registry stores config in a hierarchy: HKLM, HKCU, HKCR, HKU, HKCC.
Attackers use it for **persistence**:

```
# Rabbit hole: malicious run key
New-Item "HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" -Force
Set-ItemProperty "HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" \
-Name "UpdateSvc" -Value "C:\programdata\evil.exe"
```

Defenders audit: Run/RunOnce keys, services, WMI event subscriptions, scheduled tasks, startup folders.

Active Directory Attack Surface (Teaser)

Kerberoasting – request service tickets, crack offline

AS-REP Roasting – find accounts with pre-auth disabled

Pass-the-Hash – reuse NTLM hash, no password needed

Golden Ticket – forge a TGT with the KRBTGT hash

BloodHound – map privilege paths visually

Windows Processes/Logs Every Analyst Knows

svchost.exe – service host (many legit instances; a rogue one outside System32 is suspicious)

lsass.exe – Local Security Authority (memory theft → Mimikatz)

explorer.exe – shell (child processes outside Explorer are odd)

powershell.exe – script execution (rarely needed legitimately on endpoints; **-enc** = malicious flag)

[← Bash Scripting & Automation](#)

[Authentication, Passwords & MF...](#)